



bostoncyberx

BCX PAPER 01 • AUGUST 2026

Saying Yes to AI

The executive guide to secure AI adoption. Five decisions and 90 days separate the companies that govern AI from the companies that hope for the best.

Transform with AI. Defend with AI. Achieve with AI.

Your company is already an AI company. The question is who is in charge of that.

AI adoption in the mid-market is no longer a strategy question. It already happened. 82% of mid-market companies now have AI in production. Only 26% have it governed at scale. That is a 56-point gap between what your business is doing and what your business controls.

Inside that gap sits most of the risk your board is starting to ask about. Roughly 55% of employees use AI tools their company never approved. Client data flows into free chatbots. Contracts get summarized by services with no data agreement. Nobody logs any of it, so nobody can answer for any of it.

The instinct of many leadership teams is to slow down or ban the tools. That instinct is wrong on both counts. Bans push AI use underground, where you cannot see it. Slowing down concedes ground to competitors, and it does nothing about the attackers, who adopted AI before you did.

The better answer is to say yes on your own terms. This paper gives you the five decisions that close the governance gap and a 90-day sequence to make them real. None of the five requires a data science team. All five belong to the executive team, not to IT.

What this paper covers

- **The 56-point gap.** Why AI adoption outran AI governance, and what that costs you.
 - **The five decisions.** A sanctioned path, data rules, a named owner, an upgraded defense, and a board metric.
 - **The 90-day sequence.** Assess, build the roadmap, then operate. Each phase has a deliverable.
 - **What good looks like.** The measurable outcomes you should expect within two quarters.
-

The 56-point gap

Two numbers describe the state of mid-market AI better than any survey commentary.

82% vs 26%

82% of mid-market companies have AI in production. Only 26% have it governed at scale.

SOURCE: NETRIO MID-MARKET RESEARCH

The 56 points between those numbers are not an abstraction. They are specific, daily behaviors happening inside your company right now: an analyst pasting a client list into a free chatbot to draft an email, a manager uploading a contract for a quick summary, a developer wiring an AI service into a workflow without a security review. Each act is individually reasonable. Your people are trying to work faster. Collectively, those acts move your data outside every control you have built.

~55%

Roughly 55% of employees use AI tools their employer never approved.

SOURCE: UHY SHADOW AI RESEARCH

This is shadow AI, and it is the predictable result of demand without supply. When employees see a faster way to work and leadership offers no approved way to do it, they choose the faster way. Banning tools does not change that math. It just removes your visibility.

The gap has a second face. Attackers use AI with no governance committee and no procurement cycle. Machine-written phishing, cloned executive voices, and automated reconnaissance are now standard technique. So the companies in the gap are exposed twice: their own data leaks out through unsanctioned tools, and their defenses face adversaries who move at machine speed.

Closing a 56-point gap sounds like a multi-year program. It is not. In our experience it comes down to five decisions, and every one of them belongs on the executive team's desk.

The five decisions that close it

These are business decisions, not technical ones. Your IT team or partner will implement them, but only leadership can make them. Companies that decide all five typically close most of their governance gap within one quarter.

DECISION 01

Give people a sanctioned AI path

Shadow AI exists because the approved way to use AI does not. Pick one or two enterprise-grade AI tools with commercial data protections, buy the licenses, and tell every employee: this is the tool, here is your login, use it for real work. The moment a sanctioned path exists, most unsanctioned use dries up on its own. You are not banning AI. You are supplying it.

DECISION 02

Set the data rules

Write down, in one page, what may and may not go into an AI tool. Client names, financials, health information, and anything under NDA stay out of consumer tools, full stop. Approved tools with data agreements have wider limits. One page, plain language, signed by the CEO, covered in 20 minutes at an all-hands. A policy nobody reads is not governance. A page everybody remembers is.

DECISION 03

Name one governance owner

Somebody must own AI governance by name: the approved tool list, the data rules, exceptions, and the quarterly review. In larger firms this is a chief AI officer. In a 100-person company it is a fractional executive or a named leader with a defined mandate. What fails is the committee with no owner. When everyone owns AI risk, no one does, and the gap stays open.

DECISION 04

Upgrade the defense to match the threat

Your attackers already made their AI decision. Phishing emails are now written by machines that never misspell. Finance teams get calls in a voice that sounds exactly like the CEO because it was cloned from a webinar recording. A defense built for 2020 threats does not hold against this. The upgrade is specific: modern detection on every device, monitoring that watches around the clock, and a finance team trained to verify any payment request through a second channel, no matter whose voice asks. AI-assisted defense is how small teams see what attackers automate.

DECISION 05

Put one AI metric in front of the board

What the board reviews, the company manages. Add one line to the quarterly board pack: percentage of company AI use happening inside sanctioned, governed tools. Start honest. Most companies start below 30%. Watching that number climb toward 90% is the clearest signal, inside and outside the company, that you adopted AI on purpose rather than by accident. It also gives your board a real answer to the question they are already asking.

Why governance is the growth play

It is tempting to file these five decisions under risk management. The evidence says to file them under growth. 74% of companies remain stuck in AI pilots that never reach production, and the ones that break out share one trait: guardrails that let them deploy with confidence.

74%

74% of companies are stuck in AI pilots. Governance is what separates them from the companies seeing returns.

SOURCE: GRANT THORNTON

Mid-market companies are backing this with money: 88% plan to spend \$100K or more on AI this year. The question is whether that spend lands inside a governed program or on top of a gap.

The 90-day sequence

Five decisions become real through a sequence, not a memo. Here is the 90-day path we run with clients. Each phase ends in a deliverable you can hold.

DAYS 1 TO 30 · ASSESS

Find out what is actually happening

You cannot govern what you cannot see. The first month is discovery: which AI tools are in use across the company, sanctioned or not; what data is flowing into them; and how your current defenses score against current threats. We run this as a fixed-scope assessment across seven pillars: AI use, data, identity, detection, compliance, people, and resilience. The deliverable is a scored, board-ready report. Most executives are surprised by the tool count. Almost none are surprised by zero.

DAYS 31 TO 60 · ROADMAP

Make the five decisions and write the plan

With the facts on the table, leadership makes the five decisions in a single working session: which tools get sanctioned, what the data rules say, who owns governance, what the defense upgrade includes, and what the board metric will be. The deliverable is a 90-day roadmap with owners and dates, plus the one-page AI use policy, published to the whole company. Sanctioned tools roll out in this window so the policy arrives with the supply, not before it.

DAYS 61 TO 90 · OPERATE

Turn decisions into routine

The final month moves from project to operations: detection and monitoring go live, the finance team runs its first verification drill, the first governance review happens on calendar, and the board metric appears in the quarterly pack with a real number behind it. The deliverable is a running program with a monthly rhythm, not a binder on a shelf.

Ninety days is not a marketing number. It is roughly one quarter, which means a leadership team that starts now presents a governed AI program at its next board meeting.

What good looks like

Governance programs fail when success stays vague. Here is what you should be able to say, concretely, within two quarters of starting. Treat this list as your acceptance criteria.

- **Every employee has a sanctioned AI tool** with commercial data protections, and knows it is the approved path.

- **A one-page data policy is published** and every employee has acknowledged it. New hires get it in week one.

- **One named owner runs AI governance** with a quarterly review on the calendar and authority to approve exceptions.

- **Detection and monitoring cover every device**, watched 24/7, with a defined response plan when something fires.

- **Finance verifies every payment change through a second channel.** A cloned voice on a phone call cannot move your money.

- **The board sees one AI governance metric each quarter** and the number is moving in the right direction.

- **Shadow AI is measured, not guessed.** You can state what share of AI use is sanctioned, and the trend line.

- **AI projects ship.** At least one governed AI use case is in production and its productivity effect is measured.

Notice what this list does not require: a data science team, a seven-figure budget, or a pause on adoption. It requires decisions, sequence, and ownership. Companies that reach this state get a compounding advantage. They adopt new AI capabilities faster than competitors because the guardrails are already in place, and every new tool inherits the same rules, the same owner, and the same review.

That is the real meaning of saying yes to AI. Not yes to everything, blindly. Yes to a specific set of tools, under specific rules, watched by a specific owner, defended by a program built for the threats AI created. Yes, on your terms.



bostoncyberx

Find out where you stand in 10 minutes.

The free BCX AI & Security Readiness Assessment scores your company across the same seven pillars we use in client engagements: AI use, data, identity, detection, compliance, people, and resilience. Ten minutes, self-scored, and you get the results immediately. It is the first step of the 90-day sequence, and it costs you nothing.

bostoncyberx.com/assessment

Transform with AI. Defend with AI. Achieve with AI.

bostoncyberx

1 Marina Park Drive, Boston, MA 02210

617.241.5445 · info@bostoncyberx.com · bostoncyberx.com